

NorthBridge Technology Solutions Inc.

Information Security Management System

ISMS Executive Summary

Prepared for Executive Leadership and Board Review

NB-ISMS-000 | Version 1.0

DOCUMENT CONTROL	
Document Title	ISMS Executive Summary
Document ID	NB-ISMS-000
Version	1.0
Date	05/18/2026
Prepared By	Ashkon Irani
Reviewed By	IT Director
Presented To	Chief Executive Officer and Executive Leadership Team
Classification	Confidential
Next Review	Annual ISMS Management Review

1. Purpose of This Document

This executive summary presents the findings, status, and recommendations of NorthBridge Technology Solutions Inc.'s Information Security Management System implementation to the Chief Executive Officer and executive leadership team. It is written in plain language and is intentionally free of technical jargon. Its purpose is to give leadership a clear, honest picture of where NorthBridge stands on information security, what risks the organization currently carries, and what actions are needed to reach a fully mature security posture.

Full technical detail supporting every statement in this summary is documented in the ISMS deliverables listed in Section 2. This document does not replace those deliverables. It is the starting point for an informed leadership conversation about security investment, risk acceptance, and strategic direction.

2. ISMS Documentation Completed

The following documents have been produced as part of the NorthBridge ISMS implementation. Together they constitute a complete, ISO 27001:2022 aligned information security management system. Each document is available for review in the NorthBridge SharePoint ISMS library.

Document ID	Title	Purpose
NB-ISMS-001	ISMS Scope and Context Statement	Defines what is and is not covered by the ISMS, who the key stakeholders are, and what NorthBridge's measurable security objectives are.
NB-ISMS-002	Information Asset Inventory	Documents all 25 information assets owned or managed by NorthBridge with ownership, classification, and CIA ratings assigned to each.
NB-ISMS-003	Risk Assessment Methodology	Establishes the rules, scoring criteria, and acceptance of thresholds used to assess all information security risks consistently and repeatably.
NB-ISMS-004	Information Security Risk Register	Documents with all 25 identified risks with inherent and residual scores, current controls, treatment plans, owners, and due dates.
NB-ISMS-005	Statement of Applicability	Records NorthBridge's assessment of all 93 ISO 27001:2022 Annex A controls with implementation status and justification for each decision.
POL-001	Information Security Policy	The top-level policy establishing NorthBridge's commitment to information security, signed by the CEO.
POL-002	Acceptable Use Policy	Governs how all staff and contractors may use NorthBridge devices, systems, internet access, and data assets.
POL-003	Access Control Policy	Defines how access to NorthBridge systems is granted, reviewed, and revoked, including MFA and privileged access requirements.
POL-004	Incident Response Policy	Establishes the process for detecting, responding to, and recovering security incidents, including GoC client notification timeframes.
POL-005	Vendor Management Policy	Defines how third-party vendors are assessed, onboarded, monitored, and offboarded to manage supply chain security risk.

3. Why NorthBridge Needs an ISMS

NorthBridge is a 220-person federal IT contractor. Every day, the organization handles Government of Canada Protected B information on behalf of its clients. This is not a technical detail. It is the single most important fact about NorthBridge's security posture because it defines the consequences of a failure.

A security breach at NorthBridge is not just an IT problem. It is a client relations problem, a legal problem, and a reputational problem that could threaten the organization's ability to win and retain government contracts. The following three realities make a formal ISMS not optional for an organization in NorthBridge's position.

Reality	What It Means for NorthBridge
Contractual obligation	Government of Canada contracts require NorthBridge to demonstrate ongoing compliance with security frameworks including ITSG-33. Clients have the right to audit NorthBridge's security practices. Failure to demonstrate adequate security controls can result in contract suspension or termination.
Legal obligation	PIPEDA requires NorthBridge to protect the personal information it holds about its 220 employees. Breaches of personal data that pose a real risk of significant harm must be reported to the Office of the Privacy Commissioner. Non-compliance can result in regulatory investigation and reputational damage.
Business survival	The federal IT contracting market is built on trust. A single confirmed breach of Protected B data would damage NorthBridge's reputation in a market where reputation is everything. Cyber liability insurance premiums are also directly affected by the maturity of an organization's security program.

4. What We Are Protecting

The NorthBridge Asset Inventory identifies 25 information assets across six categories. The following is a plain-English summary of our most critical assets and why they matter.

Asset	Criticality	Why It Matters
GoC Client Project Data	Critical	This is Protected B government data. Unauthorized disclosure is a federal security incident and mandatory client notification event.
Microsoft Azure Production Environment	Critical	Hosts all client workloads. An outage or breach directly affects client SLAs and contract compliance.
IT Administrator Credentials	Critical	If compromised, an attacker gains complete control of every NorthBridge and client system. The highest impact of single assets in the inventory.
Source Code Repositories	Critical	Proprietary intellectual property and government-deployed software. Malicious code insertion here affects GoC systems directly.
Employee HR Records	Critical	Personal data of 220 employees. Subject to PIPEDA. A breach triggers regulatory notification obligations.
Microsoft 365 Tenant	Critical	All internal and client communications. A compromise here affects every employee simultaneously and exposes email history.
VPN Infrastructure	Critical	The gateway for all remote access. A compromise provides network-level access equivalent to being physically inside the building.

Of our 25 identified assets, 15 are rated Critical, 8 are rated High, and 2 are rated Medium. No assets are rated Low, reflecting the uniformly sensitive nature of NorthBridge's federal contracting work.

5. Our Current Risk Position

The Risk Register documents 25 information security risks facing NorthBridge. The following summarizes our current risk position before and after existing controls are applied.

Risk Level	Inherent Count	Residual Count	Change	Leadership Action Required
Critical (Score 20-25)	8	0	-8	None -- controls effective
High (Score 13-19)	12	4	-8	Treatment plans required within 30 days
Medium (Score 7-12)	5	17	+12	Treatment plans within 90 days or formal acceptance
Low (Score 1-6)	0	4	+4	Within risk appetite -- monitor annually

The shift from 8 Critical and 12 High inherent risks to 0 Critical and 4 High residual risks demonstrates that existing controls are working. However, 4 High residual risks and 17 Medium residual risks require active treatment plans. This is a normal and expected finding for an organization at the beginning of a formal ISMS implementation.

6. Our Five Most Important Risks

Of the 25 risks documented in the Risk Register, the following five require the most urgent leadership attention either because of their residual risk score, their direct connection to client obligations, or the immediacy of the threat they represent.

#	Risk	Residual Score	Plain English Explanation	What We Are Doing
1	RSK-005: No MFA on Microsoft 365 (Credential Compromise)	High -- 8	If an employee password is stolen via phishing, an attacker can log into their email, SharePoint, and Teams with no further barrier. This is the most common attack vector against organizations like NorthBridge.	MFA enforcement via Conditional Access is being implemented immediately. This is the highest priority control action in the entire ISMS.
2	RSK-020: VPN Compromise Enabling Network Access	High -- 8	The VPN is the door through which all remote employees' access NorthBridge and client systems. Without MFA on the	Certificate-based authentication and MFA for VPN access are being implemented

			VPN, a stolen VPN credential gives an attacker full internal network access.	as part of the access control program within 90 days.
3	RSK-025: No SIEM -- Delayed Breach Detection	High -- 6	NorthBridge currently has no central system to detect attacks in progress. The average attacker operates undetected for 197 days in organizations without monitoring. We are effectively blind to an active breach.	Microsoft Sentinel SIEM deployment is planned for Q3 2025. This is the most significant single security investment required.
4	RSK-012: Failure to Notify GoC Client Within SLA	Medium -- 3	Our contracts require us to notify government clients of a breach within defined timeframes. Without a tested incident response process, we risk breaching the contract even if the technical incident itself is well-handled.	Incident Response Policy is complete. Tabletop exercise to be conducted within 60 days. Client notification contact list being finalized.
5	RSK-007: Third-Party Vendor Breach	Medium -- 6	Several of our vendors, including our HR platform, process sensitive NorthBridge data. We have not yet formally assessed their security. A breach at one of these vendors is a breach of our data.	Vendor Management Policy is complete. Formal assessments of all Tier 1 and Tier 2 vendors to begin within 60 days.

7. Control Implementation Status

The Statement of Applicability assesses all 93 controls required by ISO 27001:2022. The following is a plain-English summary of our current implementation maturity across the four control themes.

Control Theme	Total Controls	Fully Implemented	Partially / Not Yet	Key Gap
Organizational Controls	37	8	29	Threat intelligence, supplier security, privacy program, logging and monitoring, and independent review not yet in place.
People Controls	8	3	5	Security awareness training frequency, incident reporting by staff, and post-termination security obligations need strengthening.
Physical Controls	14	5	9	Server room for CCTV, secure media disposal, clear desk policy, and equipment disposal procedure not yet implemented.

Technological Controls	34	4	30	Vulnerability management, DLP, web filtering, SIEM, and secure development of lifecycle controls are the most significant gaps.
-------------------------------	----	---	----	---

Of 93 total controls, approximately 20 are fully implemented, 40 are partially implemented, and 33 are not yet implemented. This profile is consistent with an organization at the beginning of a formal ISMS implementation rather than one approaching ISO 27001 certification. The gap is understood, documented, and addressed through the treatment plans in the Risk Register.

8. Recommended Actions for Leadership

The following actions require decisions or endorsement at the executive level. They are listed in priority order. Items 1 and 2 are urgent and should be taken within 30 days.

#	Action	Why Leadership Must Be Involved	Recommended Timeline
1	Approve and fund immediate MFA enforcement across all Microsoft 365 accounts	This is a technical action but requires leadership endorsement to override any resistance from staff or managers who find MFA inconvenient.	Immediate. This is a Critical residual risk until MFA is enforced. IT Director to confirm completion within 30 days.
2	Formally approve the Risk Register and risk acceptance criteria	ISO 27001 requires executive leadership to formally accept the organization's risk of posture. The CEO must review and sign the Risk Register approval page.	Within 30 days. Required before the ISMS can be considered formally operational.
3	Approve budget for Microsoft Sentinel SIEM deployment	Security monitoring is the most significant control gap in the ISMS. Without a SIEM, NorthBridge cannot detect active breaches. This is a capital investment decision.	Q2 2025 budget approval required for Q3 2025 implementation.
4	Endorse the ISMS policy suite and communicate security commitment to all staff	The CEO must sign POL-001 and visibly communicate to all staff that information security is a leadership priority. Culture change requires visible leadership commitment.	Within 30 days of policy approval. All staff communication is recommended.

5	Appoint a Privacy Officer responsible for PIPEDA compliance oversight	NorthBridge processes personal data of 220 employees and has no designated Privacy Officer. This is a significant PIPEDA compliance gap.	Within 60 days. Can be an existing role with additional responsibilities or a new appointment.
6	Review and approve the ISMS implementation roadmap for the next 12 months	Leadership must endorse the prioritization of control implementation activities to ensure adequate resources are allocated to security improvement.	At the next executive leadership meeting, please follow this review.

9. ISMS Implementation Roadmap

The following roadmap sets out the planned sequence of security improvements over the next 12 months. It is designed to address the highest risks first while building toward ISO 27001 certification readiness within 18 months.

Quarter	Key Activities	Success Measure
Q1 2025 (Immediate)	MFA enforced across all Microsoft 365 accounts. VPN MFA and certificate-based authentication are implemented. Risk Register formally approved by the CEO. ISMS policy suite signed and communicated to all staff. Client notification contact register completed.	Zero Microsoft 365 accounts without MFA. The Risk Register was signed. All staff policy communication is sent.
Q2 2025	EDR solution deployed on all endpoints. Patch management program formalized with SLA-based remediation targets. Vendor security assessments completed for all Tier 1 and Tier 2 vendors. A phishing simulation program was launched. DLP policies implemented in Microsoft 365.	EDR on 100% managed endpoints. All Tier 1 vendor assessments complete. The first phishing simulation was conducted with results reported.
Q3 2025	Microsoft Sentinel SIEM deployed with log sources onboarded. Disaster recovery plan documented and tested. Privileged Access Management solution implemented. Tabletop incident response exercises conducted. Privacy Impact Assessment completed for BambooHR.	SIEM lives with an active alert. DR test completed with documented results. Tabletop exercise post-exercise report issued.
Q4 2025	ITSG-33 and OSFI B-13 formal gap assessments completed. Secure development of lifecycle controls is implemented. Software	Gap assessments complete with remediation roadmaps. An internal audit report was issued to the CEO.

	Bill of Materials process established for all client-deployed software. Full ISMS internal audit conducted. ISO 27001 pre-assessment readiness review commissioned.	Pre-assessment readiness score of 75% or higher.
--	---	--

10. What Good Looks Like -- Our 18-Month Target

Within 18 months of this ISMS implementation, NorthBridge should be in the following position. This is the target state that leadership should hold the security team accountable for delivering.

- Zero Critical or High residual risks without an active, funded treatment plan in place
- MFA enforced on 100% of accounts accessing NorthBridge and client systems
- A functioning SIEM providing near-real-time detection capability with tested alert response procedures
- All Tier 1 and Tier 2 vendors formally assessed and operating under security-compliant contracts
- A tested incident response capability with demonstrated ability to meet GoC client notification timeframes
- A security awareness program with measurable outcomes including a phishing susceptibility rate below 5%
- ISO 27001:2022 certification achieved or a credible certification readiness assessment completed
- A Privacy Officer appointed and a PIPEDA compliance program operational

Reaching this target state will position NorthBridge as a security-mature federal contractor. This is increasingly a competitive differentiator in government procurement, where clients are conducting security due diligence on contractors with growing rigor following high-profile supply chain incidents in the federal ecosystem.

11. Conclusion

NorthBridge has completed the foundational work of building a formal Information Security Management System. Ten documents covering scope, asset management, risk assessment, risk treatment, control applicability, and five security policy domains have been produced and are ready for leadership approval.

The honest assessment of where NorthBridge stands today is this: the foundations are solid, the risks are understood and documented, and the treatment plans are defined. What is now required is leadership endorsement, resource commitment, and consistent execution against the roadmap in Section 9.

Information security is not a project with an end date. It is an ongoing program that requires sustained attention from leadership, adequate resourcing from the organization, and personal accountability from every employee. The ISMS provides the structure for that program. Leadership's role is to endorse it, fund it, and visibly champion it.

The IT Director is available to answer any questions arising from this summary and to present any section of the underlying ISMS documentation in more detail at the request of leadership.

12. Executive Sign-Off

By signing below, the Chief Executive Officer confirms that this Executive Summary has been reviewed, that the risk position described is understood, and that the recommended actions in Section 8 will be progressed in accordance with the timelines indicated.

Role	Name	Signature	Date
Prepared By	Ashkon Irani	[Signed]	05/18/2026
Reviewed By	IT Director	[Signed]	05/18/2026
Reviewed and Accepted By	Chief Executive Officer	[Signed]	05/18/2026

-- End of Document --

NB-ISMS-000 v1.0 | NorthBridge Technology Solutions Inc. | CONFIDENTIAL